Penetation Test Report

Target: 192.168.50.70 **Assessment Type:** Internal **Classification:** CONFIDENTIAL **Prepared by:** Automated Red Team Agent

---

1. Executive Summary

An internal security assessment was conducted on the target host `192.168.50.70` to identify vulnerabilities, misconfigurations, and potential entry points within the local network infrastructure. The assessment involved reconnaissance, service enumeration, vulnerability identification, and attempted exploitation.

The overall risk rating for this target is **Critical**. This rating is justified by the discovery of multiple high-impact vulnerabilities, including known backdoors in FTP and IRC services, as well as an active root-level bindshell on port 11524. These vulnerabilities allow for unauthenticated remote code execution and immediate full system compromise.

The assessment identified a total of **6 findings**: 2 Critical, 1 High, and 3 Medium. While several highly exploitable services were identified, a stable interactive foothold was not established during the exploitation phase of this engagement due to command execution errors during SMB inspection.

Top 3 Recommended Remediation Actions:

1. **Remove High-Risk Services:** Immediately disable and remove the bindshell service (Port 1524) and any services containing known backdoors (vsftpd 2.3.4, UnrealIRCd).
2. **Enforce Least Privilege for Network Services:** Disable anonymous and guest access for FTP and SMB services to prevent unauthorized information disclosure and share enumeration.
3. **Patch and Update Legacy Software:** Upgrade all outdated services, including Apache, Samba, and MySQL, to current, patched versions to mitigate known exploit vectors.

---

2. Scope & Engagement Details

Field	Value
Target	192.168.50.70
Phases Executed	Reconnaissance, Scanning & Enumeration, Vulnerability Identification, Exploitation
Tools Used	nmap, gobuster, nikto, enum4linux, smbclient, curl, searchsploit, metasploit, hydra
Constraints	No destructive actions; no DoS; no lateral movement beyond initial target

---

3. Methodology

Phase 1: Reconnaissance

The objective was to gather initial metadata and network context regarding the target. Techniques included analyzing IP ranges and DNS records. The key outcome was the identification of the target as an internal, private host (RFC 1918).

Phase 2: Scanning & Enumeration

The objective was to identify active services and their versions. Techniques included TCP port scanning and service-specific enumeration (SMB, HTTP, FTP). The key outcome was the discovery of a wide array of vulnerable legacy services and insecure configurations (e.g., anonymous FTP/SMB).

Phase 3: Vulnerability Identification

The objective was to map discovered services to known vulnerabilities. Techniques included using `searchsploit` and analyzing service banners against CVE databases. The key outcome was a prioritized list of exploitable vulnerabilities, including critical backdoors.

Phase 4: Exploitation

The objective was to attempt to gain unauthorized access to the target. Techniques included SMB share inspection and web server probing. The key outcome was the successful enumeration of SMB shares and web services, though a functional shell was not established in this phase.

---

4. Technical Findings

FINDING-001: vsFTPd 2.3.4 Backdoor

Field	Value
Severity	Critical
CVSS Score	N/A
CVE(s)	CVE-2011-2523
Affected Component	FTP (Port 21) - vsftpd 2.3.4
Discovered In	Phase 2 & 3

Description The version of vsftpd running on the target contains a historically documented backdoor. An attacker can trigger a remote root shell by providing a specific character sequence in the username during the login process.

Evidence Phase 2 identified `vsftable 2.3.4` with `Anonymous FTP login allowed`. Phase 3 confirmed the vulnerability via Nmap and identified the exploit method using the `:)` character sequence.

Impact Unauthenticated Remote Code Execution (RCE) with root privileges.

Remediation Immediately upgrade `vsftpd` to a non-vulnerable version or disable the FTP service if not required.

FINDING-002: UnrealIRCd Backdoor

Field	Value
Severity	Critical
CVSS Score	N/A
CVE(s)	N/A
Affected Component	IRC (Ports 6667, 6697) - UnrealIRCd
Discovered In	Phase 3

Description The running instance of UnrealIRCd is susceptible to a backdoor that allows for remote command execution.

Evidence Phase 3 identified the service via `searchsploit` and noted the high exploitability of the `linux/remote/16922.rb` Metaspiot module.

Impact Unauthenticated Remote Command Execution (RCE) on the host.

Remediation Update UnrealIRCd to the latest stable version and restrict access to the IRC ports via firewall.

FINDING-003: Apache Tomcat Directory Traversal

Field	Value
Severity	High
CVSS Score	N/A
CVE(s)	N/A
Affected Component	HTTP (Port 8180) - Apache Tomcat 5.5
Discovered In	Phase 3

Description The Apache Tomcat instance may be vulnerable to directory traversal, allowing an attacker to access sensitive files within the web application structure.

Evidence Phase 2 enumeration and Phase 3 analysis via `searchsploit` indicated potential for directory traversal or listing.

Impact Unauthorized access to sensitive configuration files (e.g., `/WEB-INF/web.xml`) and application data.

Remediation Ensure Apache Tomcat is updated to a patched version and configure strict directory permissions.

FINDING-004: PHP Information Leakage

Field	Value
Severity	Medium

Field	Value
**SSN	CWE-552
CVE(s)	N/A
Affected Component	HTTP (Port 80) - PHP/5.2.4
Discovered In	Phase 3

Description The server exposes `phpinfo.php`, which leaks critical environment details, including internal paths, loaded modules, and configuration settings.

Evidence Nikto scanning confirmed the accessibility of `/phpinfo.php` (Phase 3).

Impact Information disclosure that facilitates more targeted subsequent attacks.

Remediation Remove `phpinfo.php` from the web root or restrict access to authorized IP addresses.

FINDING-005: Insecure SMB Configuration

Field	Value
Severity	Medium
CVE(s)	N/A
Affected Component	SMB (Ports 139, 445) - Samba 3.0.20
Discovered In	Phase 2 & 3

Description The SMB service allows anonymous/guest access and has SMB signing disabled, allowing for easy enumeration of shares and users.

Evidence Phase 2 identified `Guest access allowed`. Phase 4 successfully enumerated shares `print$`, `tmp`, `opt`, and `IPC$` using `smbclient`.

Impact Unauthorized access to files within the `tmp` share and exposure of a large user list for brute-force attacks.

Remediation Disable guest/anonymous access on Samba and enforce SMB signing.

FINDING-006: Exposed phpMyAdmin

Field	Value
Severity	Medium
CVE(s)	N/A
Affected Component	HTTP (Port 80) - phpMyAdmin
Discovered In	Phase 2

Description The phpMyAdmin interface is publicly accessible on the web server.

Evidence Phase 2 `gobuster` enumeration discovered the `phpMyAdmin/` directory.

Impact If credentials are recovered (e.g., via brute-force using enumerated users), an attacker can gain full control over the backend databases.

Remintiation Restrict access to the phpMyAdmin directory to specific management workstations or remove the interface from the public-facing web server.

---

5. Attack Path Narrative

The attack path began with **Network Service Scanning** (T1046) using `nmap`, which revealed an extensive range of open ports, including high-risk services like a Bindshell (Port 1524) and an FTP service with a known backdoor.

Following the scan, **SMB Enumeration** (T1087) was performed using `enum4linux`, which successfully identified a list of valid system usernames (e.g., `msfadmin`, `root`, `mysql`). This provided the groundwork for potential credential-based attacks.

The attacker then moved to **Web Enumeration**, using `gobuster` to find sensitive directories like `phpinfo.php` and `phpMyAdmin`.

During the **Exploitation** phase, the attacker attempted to leverage the identified SMB vulnerabilities by inspecting the `tmp` share using `smbclient`. However, the attack path was interrupted at this stage due to a syntax error in the command execution, preventing the retrieval of files from the share. While a full interactive session was not achieved, the infrastructure for a complete compromise (root shell via FTP/IRC or database takeover via phpMyAdmin) was clearly identified.

---

6. Credentials & Access Captured

No interactive shells or authenticated sessions were successfully established. However, the following identifiers were observed during enumeration:

Type	Value	Source	Privilege Level
Username	`root`	SMB Enumeration	Administrative
Username	`msfadmin`	SMB Enumeration	User/Service
Username	`mysql`	SMB Enumeration	Service
Username	`ftp`	SMB Enumeration	Service

---

7. Remediation Roadmap

ID	Finding	Severity	Effort	Priority	Recommended Owner
1	Remove Backdoor Services (FTP/IRC)	Critical	Low	P1	System Administrator

ID	Finding	Severity	Effort	Priority	Recommended Owner
2	Disable Anonymous SMB Access	Medium	Low	P1	Network/System Admin
3	Secure/Remove phpMyAdmin & phpinfo	Medium	Low	P2	Web Developer
4	Patch Apache and Samba	High	Medium	P2	System Administrator

8. Appendices

Appendix A — Reconnaissance Data (Phase 1 Summary)

- **Target IP:** 192.168.50.70
- **Network:** 192.168.0.0/16 (Internal)
- **Role:** Likely internal server/workstation.

Appendix B — Scan & Enumeration Results (Phase 2 Summary)

Port	Service	Version	Notes
21	FTP	vsftpd 2.3.4	Anonymous allowed
80	HTTP	Apache 2.2.8	phpinfo found
139/445	SMB	Samba 3.0.20	Guest access allowed
1524	Bindshell	Metasploitable	**Root Shell Available**
6667	IRC	UnrealIRCd	Backdoor identified

Appendix C — Identified Vulnerabilities (Phase 3 Summary)

1. **CVE-2011-2523** (vsFTPd Backdoor) - Critical
2. **UnrealIRCd Backdoor** - Critical
3. **Apache Tomcat Traversal** - High
4. **CWE-552** (PHP Info Leak) - Medium
5. **SMB Guest Access** - Medium

Appendix D — Exploitation Attempts (Phase 4 Summary)

Vulnerability	Tool	Outcome
SMB Share Enumeration	`smbclient`	Success
Tomcat Discovery	`curl`	Success
SMB Content Inspection	`smbclient`	**Failed (Syntax Error)**

Appendix E — Post-Exploitation Results (Phase 5 Summary)

No foothold was obtained; post-exploitation phase was not executed.